

01-BRUTE-FORCE-SSH

Laboratorio de Detección de Amenazas en SIEM

Detection Scenario

This lab documents the detection of repeated failed SSH authentication attempts against a Linux server using Splunk Enterprise. The scenario simulates brute force activity commonly associated with initial access attempts against exposed SSH services.

Objective

Detect repeated failed SSH login attempts and identify brute force patterns through centralized log analysis.

Environment

- **Victim Server:** Ubuntu Server
- **SIEM Platform:** Splunk Enterprise
- **Log Source:** Linux authentication logs
- **Service:** OpenSSH service enabled

Attack Simulation

Multiple failed SSH login attempts were generated from an attacker machine (Kali Linux) using the **Hydra** tool against the target Linux endpoint. The activity simulated automated credential guessing behavior targeting remote access services.

Data Source

Log File	/var/log/auth.log
Index	main
Sourcetype	Ubuntu-Victima

Detection Logic & SPL Queries

1. Base Failed SSH Authentication Attempts (Resultados de búsqueda generales)

Query utilizada para identificar todos los eventos de contraseñas fallidas dentro del sourcetype de la víctima:

```
index=main sourcetype="Ubuntu-Victima" "Failed password"
```

2. Top Source IP Activity (Estadísticas de la IP de origen atacante)

Query utilizada para extraer de forma dinámica las direcciones IP con expresiones regulares y contabilizar el volumen de ataques por origen:

```
index=main sourcetype="Ubuntu-Victima" "Failed password"
| rex "from (?<src_ip>\d+\.\d+\.\d+\.\d+)"
| stats count by src_ip
| sort - count
```

3. Authentication Timeline (Línea de tiempo de la autenticación)

Query para graficar de forma temporal el comportamiento de los fallos e identificar picos o anomalías de tráfico:

```
index=main sourcetype="Ubuntu-Victima" "Failed password"
| timechart count
```

4. Target User Analysis (Análisis de cuentas de usuario objetivo)

Query para mapear cuáles nombres de usuario (tanto válidos como inválidos) están siendo los más atacados por el software automatizado:

```
index=main sourcetype="Ubuntu-Victima" "Failed password"
| rex "for (?<user>\w+)"
| stats count by user
| sort - count
```

Analysis

The analysis identified repeated failed SSH authentication attempts against the same target account originating from a single external IP address. Event frequency and temporal concentration were consistent with automated brute force behavior. The generated telemetry confirmed successful visibility into authentication-related attack activity through Splunk.

Findings

- Multiple failed SSH logins detected within a very narrow time window.
- Repeated authentication attempts from a single, persistent source IP address (extracted as `src_ip`).
- Authentication failure spikes clearly observable through SIEM timechart telemetry dashboards.
- User account targeting activity identified, focusing heavily on administrative users (e.g., `root`) and invalid accounts.

MITRE ATT&CK Mapping

- **Technique:** T1110 — Brute Force

Impact

Successful brute force activity may lead to unauthorized initial access, credential compromise, and potential lateral movement opportunities inside the internal network.

Classification

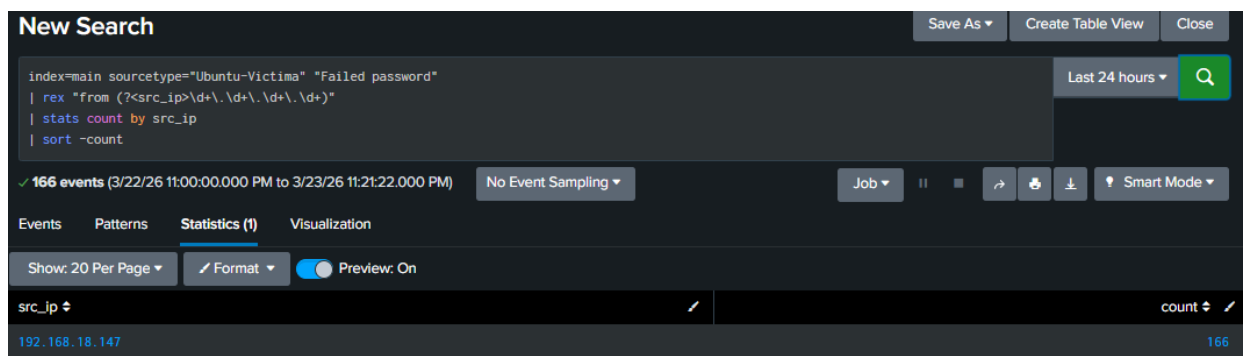
True Positive (Controlled laboratory simulated activity).

Recommendations

1. Implement `fail2ban` or equivalent automated blocking controls on the endpoint to drop IPs with multiple consecutive failures.
2. Restrict SSH access through secure corporate VPN corridors or explicit IP allowlisting.
3. Disable password authentication where possible, enforcing public/private SSH Key authentication.
4. Monitor authentication anomalies and establish real-time alerting for failed login spikes within Splunk Enterprise.

Screenshots Required

- **Screenshot 1:** Failed authentication search results (Eventos crudos en Splunk).



- **Screenshot 2:** Source IP statistics



- **Screenshot 3:** Authentication timeline dashboard



- **Screenshot 4:** Raw event and User analysis (Gráfico de pastel o tabla con usuarios más atacados).

